

docs/modules/user-profile.md

Фойдаланувчи профили + 2FA + Telegram - СПЕС

Ҳолат: **ТАСДИҚЛАНГАН** (фойдаланувчи: «tasdiqlayman»). Савол-жавоб қарорлари: 2FA = TOTP илова; 2FA SUPER_ADMIN'га МАЖБУРИЙ, қолганларга ихтиёрий; Telegram ҳозирча ФАҚАТ улаш (қўшимча мақсадлар кейин аниқланади); email фақат маълумот майдони. Карталар: 101 очилди (бажарувчи кейин белгиланади - фойдаланувчи қарори: DEPLOY 4.2 дан кейин); 102/103 - 101 ёпилгач.

Мақсад

Менюдаги «Паролни алмаштириш» банди (сайдбар footer'ида - sidebar.jte, /profile/password) тўлақонли **Профиль** бўлимига айланади: фойдаланувчи ўз профилини кўради/тахрирлайди - email, парол, 2FA, Telegram. SUPER_ADMIN эса Созламаларда компания Telegram botini улайди.

1. Профиль саҳифаси (/profile) - DEC-101

- Меню: «Паролни алмаштириш» → «Профиль» (ҳавола /profile).
- GET /profile: username + роль (read-only, роль тавсифи билан), шахсий маълумотлар формаси (қуйида), парол алмаштириш блоки (мавжуд ProfileController оқими шу саҳифага кўчади - эски /profile/password GET уни redirect қилади), 2FA блоки (102), Telegram блоки (103). Блоклар алоҳида fragment'ларда (profilePassword/profile2fa/profileTelegram) - кейинги карталар параллел ишлай олиши учун.
- **Шахсий майдонлар** (фойдаланувчи кеч, ҳаммаси ихтиёрий/nullable, changeset 057):
- email - формат текшируви (BR-USR янги код, контактдаги EMAIL нақши), фақат маълумот - login ўзгармайди;
- **gender** - enum MALE/FEMALE + «кўрсатилмаган» (null);
- **birthdate** - DATE, келажак сана бўлмайди (BR); экранда CompanySettings timezone қоидаcига мос кўрсатилади;
- **phone** - оддий матн майдони (контактдаги phone нақши, қатъий формат мажбурланмайди);
- **profile image** - расм (аватар): upload фақат png/jpeg/webp, ҳажм чегараси 2MB (BR); сақлаш мавжуд Attachment инфраси орқали (app_user.profile_image_id FK → attachment; алоҳида сақлаш тизими ёзилмайди); кўрсатиш GET /profile/image (ўз расми) - Content-Disposition inline + nosniff (094 view endpoint қоидалари билан бир хил; SVG ТАҚИҚ - XSS); ўчириш турмаси (default - бош ҳарфли доира placeholder). Расм UX БИТТА виджет: аватарнинг ўзи контрол (ўзгартириш/ўчириш) - алоҳида Choose-file/юклаш блоки эмас (жонли топилма). **Сайдбарда аватар** (sidebar.jte sbfoot): профиль менюси РАСМЛИ (аватар+ном, расм йўқ → placeholder) - 1-БОСҚИЧ (жонли топилма; аввал 2-босқич эди).
- **email admin томонидан ҳам** (жонли топилма): email профилда self-service, ЛЕКИН admin ҳам /users/{id}/edit'да киритади (ихтиёрий) - UserForm/UserController.
- **Бир марталик парол** (жонли топилма): admin парол қўйганда/reset'да `app_user.must_change_password = true` (changeset 057); login'дан кейин чиройли alert «Паролингизни алмаштиринг» → change-password, user алмаштиргач флаг тушади (auth-security-policy мажбурий-алмаштириш механизми - парол-муддати шуни улашади).
- ХАВФСИЗЛИК ТУЗОҚИ (092 мероси): UrlPermissionMap'га кирмаган POST камида битта соҳа EDIT талаб қилади - профилнинг ҲАР ЯНГИ POST'и SecurityConfig'да /profile/password каби АНИҚ ЁЗИЛГАН authenticated қилинади (VIEWER_AUDITOR ҳам ўз профилини бошқара олади).

2. 2FA - TOTP (DEC-102)

- Усул: RFC 6238 TOTP (Google Authenticator/Authy мос), 30s ойна, 6 рақам, ± 1 қадам толеранс. Имплементация ўзимизники (HMAC-SHA1, unit тест RFC вектор билан) - ташқи 2FA хизмат ЙЎҚ. QR: zxing (core+javase, test эмас main dependency) - otpauth:// URI'дан PNG endpoint (фақат setup сессиясида, cache'ланмайди).
- Маълумот (changeset 058): app_user.totp_secret (nullable, Base32), totp_enabled boolean; user_recovery_code жадвали (user_id, code_hash bcrypt, used_at) - ёқишда 8 та бир марталик захира код КЎРСАТИЛАДИ (қайта кўрсатилмайди).
- Ёқиш оқими (профилда): «2FA ёқиш» → server secret яратади → QR + қўлда киритиш калити → фойдаланувчи биринчи кодни киритади → тўғри бўлса enabled + захира кодлар экрани. Ўчириш: жорий парол + амалдаги код талаб қилинади.
- Login оқими: парол тўғри ва totp_enabled бўлса - сессияда PRE_OTP ҳолат, /login/otp саҳифасига (фақат код майдони; захира код ҳам қабул қилинади - used_at белгиланади). Тўғри код → тўлиқ authentication. Нотўғри уринишлар lockout счётигига киради (LoginAttemptListener нақши, BR-USR-009 оиласи). Аудит: OTP муваффақият/рад ёзувлари (мавжуд LOGIN нақшлари ёнида).
- SUPER_ADMIN мажбурий:** totp_enabled=false SUPER_ADMIN login қилса тизим ишлатишдан олдин /profile?setup2fa га мажбурий йўналтирилади (interceptor/filter, фақат profile+logout+static очик) - ёқмагунча бошқа саҳифа очилмайди. Мавжуд admin'лар учун: deploy'дан кейин биринчи kirishda шу оқим (grace давр йўқ - хавфсиз томон). Қолган роллар: ихтиёрий.
- Тиклаш йўли: захира кодлар; улар ҳам йўқолса - бошқа SUPER_ADMIN /users'дан 2FA reset қилади (BR: ўзиникини reset қилолмайди - фақат парол+код билан ўчиради). Ягона SUPER_ADMIN ўзини қулфлаб қўйса - DB даражасида қўлда (docs/runbook izohi, UI йўқ).

3. Telegram улаш (DEC-103)

- Фойдаланувчи томони (профил блоки):** «Telegram улаш» → server бир марталик код (TTL 10 дақиқа) → deep link `https://t.me/?start=` (тугма + QR эмас, линк кифоя). Фойдаланувчи bot ичида Start босади → poller кодни кўради → app_user.telegram_chat_id + telegram_username сақланади (changeset 059) → профилда «Уланган: @username» + узиш тугмаси. Bot созланмаган бўлса блок «Bot созланмаган (SUPER_ADMIN Созламаларда улайди)» деб кўрсатади.
- SUPER_ADMIN томони (/settings/telegram бўлими):** token киритиш (кўрсатишда маскаланади: 12345:AB●●●●), «Текшириш/сақлаш» - Bot API getMe чақирилиб bot номи кўрсатилади; ўчириш тугмаси. Сақлаш: telegram_settings жадвали (changeset 059: token_enc, bot_username, update_offset). ТАҚИҚ: token log'га (logging.md қويدаси), аудит диффига ва чатга ЁЗИЛМАЙДИ (аудитда фақат «token янгиланди» факти).
- ТОКЕН САҚЛАНИШИ (арбитр қарори):** токен базада ШИФРЛАНГАН - telegram_settings.token_enc (AES-GCM 256, ҳар ёзувда янги IV; shared.service.SecretCrypto). Калит базада ЭМАС: AVERPO_SECRET_KEY env (base64, 32 байт) - база dump/захираси (масалан миграция олди backup'и) токенини ошкор ҚИЛМАЙДИ. Калит берилмаса токен сақланмайди (BR-TG-004); dev/test профилида DEV калит ишлайди (AdminUserInitializer fail-safe нақши: номаълум/ профилсиз муҳит доим production). Калит алмаша эски токен ўқилмайди - бот «созланмаган» ҳолатга тушади (WARN), SUPER_ADMIN қайта киритади; тизим йиқилмайди. Рад этилган вариантлар: очик матн устуни (захирада bearer кренделш очик ётарди), фақат env токени (спецнинг UI оқими йўқоларди, алмаштириш SSH талаб қиларди).
- Bot API клиенти:** расмий `com.github.pengrad:java-telegram-bot-api` кутубхонаси (DEC-132) - кутубхона типлари TelegramBotClient портидан ташқарига чиқмайди (тест seam + lock-in изоляцияси). Модул: `com.averpo.erp.plugins.telegram.*`.

- **РЕЖИМ (профил асосида, DEC-138):** Telegram янгиликларни икки йўл билан олади - иккови ЎЗАРО ИСТИСНО (Telegram webhook ва getUpdates бир вақтда 409):
- **дев/тест профил** (локал `./gradlew bootRun`) → **polling** (long getUpdates). Локалда webhook имконсиз - Telegram localhost'га ета олмайди.
- **профилсиз prod → webhook** (poller ишламайди).
- **Poller** (дев, `@Profile("dev")`): фон daemon thread (SmartLifecycle), плагин ёқиқ + токен бор бўлса long getUpdates (offset сақланади, рестартда давом). Фақат `/start <code>` ишланади, қолгани жим (жавоб: «Профиль уланди» / «Код нотўғри ёки эскирган»). Тармоқ хатоси тизимни йиқитмайди - WARN + backoff. Старт'да қолдиқ webhook'ни ўчиради (getUpdates 409 бермасин).
- **Webhook** (prod, DEC-138): `POST /telegram/webhook` (permitAll + CSRF ўчиқ - Telegram аутентификация/CSRF юбормайди). Ҳимоя **ФАҚАТ** `X-Telegram-Bot-API-Secret-Token` header'ида: registrar яратган сир билан **constant-time** таққос (`MessageDigest.isEqual`). Оқим - секрет ОЛДИН: нотўғри/йўқ header → **401** (плагин ҳолатидан қатъи назар - on/off аутентификациясиз ошкор бўлмасин); тўғри секрет → `parseWebhookUpdate` → `handleUpdate` → **200** (ишлаб бўлмаган хабар ҳам 200 - Telegram 2xx кутади). Секрет `webhook_secret_enc` (changeset 068) - `token_enc` билан бир хил ШИФРЛАШ. `handleUpdate` мантиғи polling билан АЙНАН бир хил.
- **AVERPO_PUBLIC_URL** env (webhook режимда МАЖБУРИЙ, масалан `https://app.averpo.com`) - Telegram'га POST манзилини қуриш учун (+ `/telegram/webhook`). Йўқ бўлса ERROR лог + webhook рўйхатдан ўтмайди (илова ЙИҚИЛМАЙДИ - fail-safe; SUPER_ADMIN ҳолатни кўради).
- **Webhook registrar** (prod, `@Profile("!dev & !test")`, `ApplicationRunner`): старт'да ва плагин toggle/токен ўзгариши (AFTER_COMMIT event) webhook'ни `setWebhook` / `deleteWebhook` қилади; секрет йўқ бўлса `SecureRandom` яратиб шифрлаб сақлайди (барқарор).
- Мақсад ҳозирча **ФАҚАТ** улаш (фойдаланувчи қарори); билдиришнома турлари кейин алоҳида келишилади (2-босқич).
- **АРХИТЕКТУРА (фойдаланувчи):** биз бир-tenant (`CompanySettings singleton`) - **ҳар компания/deployment ўз ботини** яратади (`@BotFather`), умумий платформа боти ЙЎҚ (кўп-tenant SaaS'да келажакда). Telegram = **ихтиёрий кенгайтма**: токен созланса ЁҚИЛАДИ (улаш блоки + poller), йўқ бўлса ЯШИРИН (соф plugin-тизим эмас - ихтиёрий фича ҳолати билан гейтланади). Карта: DEC-103.

4. App_user ↔ employee улаш (DEC-101 доирасида, changeset 057)

- Фойдаланувчи талаби: `app_user`'ни ходимга улаш имкони.
- Бизда алоҳида `Employee entity` ЙЎҚ - «ходим» = `Contact (type= EMPLOYEE, payroll employeeId` шуни кўрсатади). Демак улаш = `app_user`'га ихтиёрий `employee_contact_id` FK → `contact (nullable, ON DELETE SET NULL` - контакт ўчса login синмасин).
- Ким ўрнатади: **super-admin**, `/users/{id}/edit` 'да (административ боғланиш, self-service ЭМАС - фойдаланувчи ўзини ходимга улай олмайди). Профиль саҳифасида (`/profile`) ходим боғланган бўлса `read-only` кўринади («Ходим: <ном>»).
- BR: битта `EMPLOYEE` контакт фақат битта фаол `app_user`'да (1:1 ихтиёрий) - бир ходим икки login'га уланмайди; танлагич фақат `type=EMPLOYEE` контактларни кўрсатади.
- Танлагич = **СМБОВОХ (қидирувли)** (жонли топилма): мавжуд `combobox (/js/combobox.js, DEC-066)` - ходим кўп бўлса ичида `search` билан топилади. Оддий `select` ЭМАС.
- Мақсад ҳозирча: `app_user` қайси ходимга тегишлигини БИЛИШ ва КЎРСАТИШ. Кейин `org-structure` (ходим қайси unit'да) ва `payroll` билан боғланади - `docs/modules/org-structure.md`.

Тартиб ва боғлиқликлар

101 (саҳифа пойдевори) АВВАЛ → 102 ва 103 кейин (иккиси ҳам ўз fragment'ида - параллел мумкин, лекин иккаласи SecurityConfig'га тегса кетма-кет афзал). Changeset'лар: 057 (email, gender, birthdate, phone, profile_image_id, employee_contact_id) - 101, 058 (totp + recovery жадвал) - 102, 059 (telegram) - 103. 101 катталиги энди M/L (шахсий майдонлар + аватар upload/serve + employee улаш).

BR кодлар (КАТАЛОГ-АВВАЛ, рақамлар имплементацияда грер билан)

Email формати; birthdate келажакда бўлмайди; profile image тури (png/jpeg/webp) ва ҳажми (2MB); OTP нотўғри/эскирган; 2FA ёқиш тасдиқ коди нотўғри; 2FA ўчиришда парол/код нотўғри; SUPER_ADMIN 2FA'сиз тизим ишлатолмайди; Telegram улаш коди нотўғри/эскирган; bot token нотўғри (getMe рад).

Тестлар (минимум)

TOTP unit (RFC 6238 вектор + ойна толеранси); login+OTP интеграция (тўғри/нотўғри/захира код/lockout); SUPER_ADMIN мажбурий redirect; email формат BR; recovery кодлар бир марталик; telegram код TTL + улаш servis тести (Bot API mock); token маскаси; барча янги POST'лар VIEWER_AUDITOR билан ҳам ишлаши (ўз профили) лекин бошқа фойдаланувчиникига эмас.

2-босқич (ҳозир ЭМАС)

Билдиришнома турлари (login огоҳлантириши ва б. - фойдаланувчи рўйхати билан); Telegram 2FA канали; email login/парол тиклаш (SMTP); webhook режими (polling ўрнига).